MDR · CONSOLA DE TRIAJE

MANUAL DE PRODUCCIÓN

MDR de triaje asistido

Instalación, uso y mantenimiento

Edición: 1.0

Software: MDR 1.7

Fecha: Noviembre 2026

Índice

Introducción

1. Para quién es este manual 4
2. Cómo funciona el MDR 4
3. Cómo queda instalado 5
4. Lo que el cliente decide antes de instalar 6

Instalar

5. Requisitos del equipo MDR 7
6. Instalar el servicio 7
7. Escribir el perfil del cliente 9
8. Conectar el SIEM 11
9. Dar acceso a los analistas 12
10. Dar al MDR acceso a los equipos 13
11. Comprobar la instalación 14
12. Abrir la automatización poco a poco 15

Usar la consola

13. Entrar y moverse por la consola 16
14. El Panel 17
15. Cómo resolver las aprobaciones 18
16. Cómo seguir la Consola 19
17. Cómo pausar la automatización y revertir contenciones 20
18. Cómo leer una decisión 21
19. Cómo llevar un incidente 22
20. Cómo leer el mapa de la red 22
21. Ubicaciones y Watchlist 23
22. Cómo comprobar la integridad de la traza 23
23. Cómo sacar el informe en PDF 24

Configurar

24. Políticas de respuesta 25
25. Conectividad 25
26. Estado de servicios 26
27. Recortes ante fallos de contención 27

Mantener

28. Arrancar, parar y ver el registro 28
29. Vigilar el MDR y los servicios 28
30. Copias de seguridad y retención 29
31. Actualizar el MDR 30

32. Cambiar el perfil 30
33. Rotar claves y tokens 31
34. Desinstalar 31

Anexos

Anexo A. El fichero triaje.env 32
Anexo B. La herramienta mdr 33
Anexo C. Puertos y flujos de red 33
Anexo D. Familias de ataque y su respuesta 34
Anexo E. Por qué falló una contención 34
Anexo F. Problemas frecuentes en la instalación 35
Anexo G. Preguntas frecuentes 35
Anexo H. Glosario 36
Anexo I. Límites conocidos 37

Introducción

1. Para quién es este manual

El MDR recibe las alertas que ya genera el SIEM del cliente, separa las amenazas reales del ruido, propone una respuesta y, si la política del cliente lo permite, la ejecuta en el equipo afectado. Todo lo que decide queda en una traza que no se puede alterar sin que se note. La consola web es donde un analista ve todo eso, decide lo que le toca y lo audita después.

Este manual tiene tres lectores:

Bloque	Para quién	Qué cubre
Introducción	Todos	Cómo funciona el MDR y qué hay que decidir antes
Instalar	Administración de sistemas, o el técnico que instala	Del paquete al servicio en marcha, conectado al SIEM y a los equipos
Usar la consola	Analistas	El Panel, las aprobaciones, las contenciones, la investigación y el informe
Configurar	Analistas con experiencia	Políticas, Conectividad, Estado de servicios y recortes
Mantener	Administración de sistemas	Registro, vigilancia, copias, actualizaciones, claves y desinstalación

El MDR se entrega como un paquete, `mdr-<versión>.tar.gz`, con el software y la consola listos para usar, la herramienta de administración `mdr` (anexo B) y las plantillas de instalación en `deploy/`: la unidad de systemd, la configuración (`triaje.env.ejemplo`) y un perfil de ejemplo (`perfil.ejemplo.yml`).

Cada tarea sigue, cuando aplica, la misma estructura: para qué sirve, una caja **«Quién puede»**, **Antes de empezar**, **Pasos** y **Qué ocurre después**. Los textos entre comillas latinas, como «Aprobar», son los rótulos tal como aparecen en la pantalla.

A lo largo del manual se usa un caso de ejemplo: **un ataque de fuerza bruta por SSH desde la IP 203.0.113.9 contra el servidor web01** del perfil de ejemplo. Llega como alerta, espera aprobación, se contiene, se revisa y sale en el informe del mes. La IP es de documentación: no es de nadie.

2. Cómo funciona el MDR

Del SIEM a la contención

Cada alerta recorre siempre el mismo camino:

1. **Agrupación.** Las alertas repetidas del mismo origen se juntan en un incidente, y lo que ya se decidió se suprime para no repetir trabajo.
2. **Clasificación.** El incidente cae en una de diez familias de ataque (anexo D), o se marca como falso positivo o «no soportada».

3. **Propuesta.** Una política determinista elige una acción de un catálogo cerrado: bloquear una IP, cortar una conexión, aislar un equipo…
4. **Filtro del cliente.** El perfil del cliente permite la acción en automático, la retiene para un analista, la sustituye por otra más suave o la veta.
5. **Ejecución y verificación.** El MDR entra por SSH en el equipo con un usuario de mínimo privilegio, ejecuta la acción y comprueba que quedó puesta.
6. **Escalada.** Si no puede contener en el equipo, sube por la cadena de cortafuegos hasta el perímetro.
7. **Traza.** Todo queda anotado y encadenado por hash.

Tres ideas que conviene tener presentes

- **El MDR no detecta: refina.** Lo que el SIEM no ve, el MDR tampoco.
- **Lo que roza un servicio lo decide una persona.** Para eso existe la cola de aprobaciones.
- **Ante la duda, lo más grave.** Si algo no cuadra, el sistema retiene o avisa; nunca da algo por contenido sin haberlo verificado.

Decisión, incidente y campaña

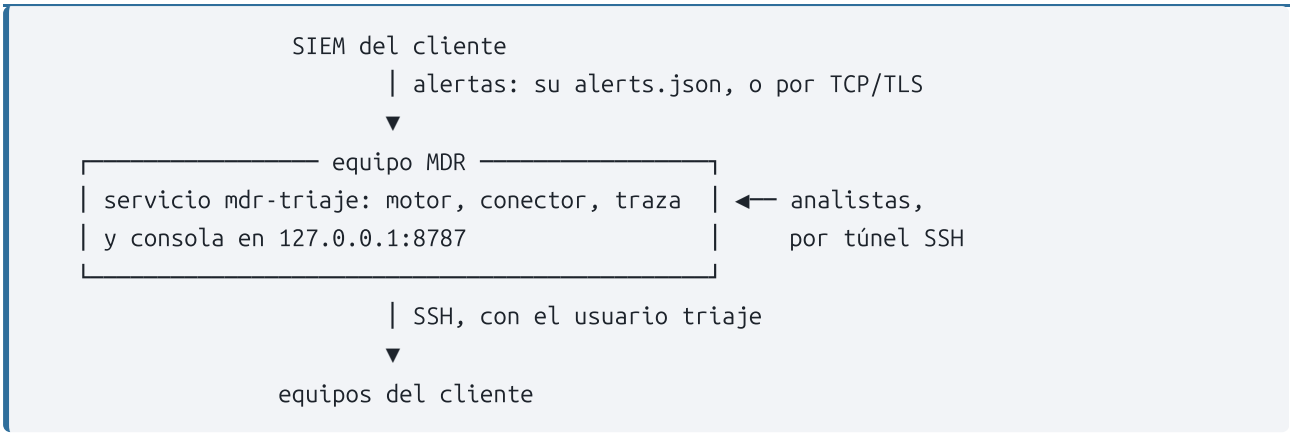
Concepto	Qué es
Decisión	Lo que el MDR resolvió sobre un incidente: su clase, la acción y en qué acabó
Incidente	Un ataque concreto, con sus alertas agrupadas
Campaña	Los incidentes de un mismo bloque de IPs (/24). En la consola se gestiona como un caso

Cómo acaba una decisión

Desenlace	Qué significa
Contenida	La acción se ejecutó y se verificó, en el equipo o tras escalar
Pendiente	Espera a un analista en Aprobaciones
Rechazada / reclasificada	Un analista no la ejecutó, o corrigió su clase
Degradada / vetada	La política del cliente la sustituyó por otra más suave, o la prohibió
Fallida	No se pudo contener: la consola dice por qué (anexo E)
Enrutada	No se contiene por diseño: se deriva a otro equipo (por ejemplo, appsec)
Falso positivo / no soportada	No era una amenaza, o cae fuera de las familias que el MDR trata

3. Cómo queda instalado

Todo el MDR corre en **un equipo**, el equipo MDR, situado en el plano de gestión del cliente: alcanza el SIEM y la interfaz de gestión de los equipos que debe contener. Las alertas llegan del SIEM; el MDR sigue su `alerts.json` o las recibe por la red. Las contenciones salen por SSH con un usuario propio, `triaje`, que en cada equipo solo puede ejecutar los comandos que permite su papel. La consola solo escucha en `127.0.0.1`: los analistas entran por un túnel SSH (sección 9).



Una instalación atiende a **un cliente**: carga un solo perfil. Dos clientes son dos instalaciones.

Ruta	Qué contiene	Dueño
`/opt/mdr`	El software, la consola y la herramienta `mdr`	root, solo lectura para el servicio
`/etc/mdr/triaje.env`	La configuración del servicio, con sus secretos	root, `0600`
`/etc/mdr/perfil.yml`	El perfil del cliente	root, legible por `triaje`
`/var/lib/mdr`	El estado: la traza, lo editado en la consola, los hallazgos y la clave del conector	`triaje`, `0700`

4. Lo que el cliente decide antes de instalar

Nada de esto lo resuelve el software. Conviene tenerlo por escrito antes del primer día.

Qué	Por qué
Autorización para actuar	Qué puede contener el MDR y sobre qué equipos. Sin ella, todo lo decide un analista
El equipo MDR	Dónde corre, quién lo administra y con qué alcance de red
El inventario de la red	Equipos, zonas, cortafuegos y dependencias: es el perfil (sección 7)
Cómo llegan las alertas	Fichero local o envío por red, y desde qué IPs (sección 8)
Quién administra cada equipo	Es quien ejecuta en él el paquete de alta (sección 10)
Los analistas	Quién entra en la consola y con qué nombre firma (sección 9)
El escaneo de postura	Si se autoriza escanear los equipos y con qué cadencia. Sin él, nada se contiene solo (sección 7)
Custodia de secretos	Si la clave del conector y la de la traza viven en un gestor de secretos
Control de cambios	Quién aprueba cambios en el perfil

Instalar

5. Requisitos del equipo MDR

Quién puede: administración de sistemas del cliente, con `sudo` en el equipo MDR.

Qué	Detalle
Sistema	Linux con systemd
Python 3 y PyYAML	Probado con Python 3.14. Es la única dependencia
Cliente OpenSSH	`ssh` y `ssh-keygen`: el conector y la generación de su clave
`tail`, `curl`	Seguir el `alerts.json` y comprobar la salud
`nmap`	El escaneo de postura (sección 7). Opcional, pero sin él nada se automatiza
Red	Alcanzar el SIEM y la gestión SSH de cada equipo; NTP sincronizado con el SIEM y los equipos
Hardware	Modesto: no usa GPU. En un equipo sin GPU, el motor decide unas 565 alertas por segundo. Las bases de países y de organizaciones ocupan menos de 100 MB de memoria
Navegador de los analistas	Uno actual, en el puesto de cada analista

Nota: el reloj importa. El MDR correlaciona ráfagas por la hora de cada alerta; si el SIEM, el MDR y los equipos no comparten NTP, las ráfagas se cuentan mal.

En Debian o Ubuntu:

```
sudo apt install python3 python3-yaml openssh-client curl nmap
```

6. Instalar el servicio

Quién puede: administración de sistemas del cliente, con `sudo` en el equipo MDR.

Antes de empezar

- El equipo cumple los requisitos de la sección 5.
- Tienes el paquete `mdr-<versión>.tar.gz` en el equipo.
- Tienes, o vas a escribir, el perfil del cliente (sección 7).

Pasos

1. **Crea el usuario del servicio.** No tiene shell ni contraseña:

```
sudo useradd --system --home-dir /var/lib/mdr --no-create-home \
    --shell /usr/sbin/nologin triaje
```

2. **Instala el software**, propiedad de root:

```
sudo mkdir -p /opt/mdr
sudo tar -xzf mdr-<versión>.tar.gz -C /opt/mdr
```

3. **Crea la configuración** a partir de la plantilla y edítala (anexo A):

```
sudo install -d -m 0750 -o root -g triaje /etc/mdr
sudo install -m 0600 /opt/mdr/deploy/triaje.env.ejemplo /etc/mdr/triaje.env
sudo nano /etc/mdr/triaje.env
```

4. **Instala el perfil** del cliente (sección 7):

```
sudo install -m 0640 -o root -g triaje perfil-cliente.yml /etc/mdr/perfil.yml
```

5. **Crea el directorio de estado y una postura vacía.** Se rellena después con `mdr escanear` (sección 7):

```
sudo install -d -m 0700 -o triaje -g triaje /var/lib/mdr
echo '{"nodos": {}}' | sudo -u triaje tee /var/lib/mdr/postura.json
```

6. **Instala y arranca el servicio:**

```
sudo cp /opt/mdr/deploy/mdr-triaje.service /etc/systemd/system/
sudo systemctl daemon-reload
sudo systemctl enable --now mdr-triaje
```

7. **Mira el arranque:** `journalctl -u mdr-triaje -f`. Debe salir la línea `[inicio] monitor activo` y, si el perfil tiene algo incoherente, líneas `[aviso] perfil: …`.

Nota: en `/etc/mdr/triaje.env` los comentarios van **siempre en su propia línea**. systemd no quita un comentario puesto al final: `TRIAJE_SSH_MODO=directo # nota` deja el modo en «directo # nota» y el conector no lo reconoce.

Qué ocurre después

El servicio arranca solo con el equipo y se reinicia si cae. Hasta la sección 10 el conector está «sin configurar»: el MDR decide y lo muestra en la consola, pero **no ejecuta nada** en los equipos.

Nota: el servicio no puede escribir en `/etc` ni en `/opt/mdr`, solo en `/var/lib/mdr`. Por eso la clave del conector vive allí.

Las bases de países y de organizaciones

El país y la organización (el ASN, por ejemplo «Google LLC») de cada IP atacante salen de dos bases locales: el MDR no consulta ningún servicio externo. Se usan las de **DB-IP**, gratuitas y actualizadas cada mes: «IP to Country Lite» y «IP to ASN Lite».

1. En un equipo con internet, descarga los dos CSV, aceptando su licencia: https://db-ip.com/db/download/ip-to-country-lite (`dbip-country-lite-AAAA-MM.csv.gz`) y https://db-ip.com/db/download/ip-to-asn-lite (`dbip-asn-lite-AAAA-MM.csv.gz`).
2. Cópialos al equipo MDR e instálalos:

   ```
   sudo /opt/mdr/bin/mdr instalar-geoip dbip-country-lite-2026-11.csv.gz
   sudo /opt/mdr/bin/mdr instalar-asn dbip-asn-lite-2026-11.csv.gz
   sudo systemctl restart mdr-triaje
   ```

   Cada orden comprueba el fichero antes de sustituir la base instalada: uno defectuoso, o una base de un tipo por la del otro, no la estropea.
3. En la Consola salen «[inicio] geolocalización: … rangos» e «[inicio] ASN: … rangos». Sin una base, sale un aviso: sin la de países, los orígenes públicos aparecen como «Pública (sin base de geolocalización)»; sin la de ASN, sin organización.

Nota: la licencia de las bases Lite de DB-IP (CC BY 4.0) exige mostrar su atribución donde se ven sus datos. La consola enlaza «IP Geolocation by DB-IP» al pie del menú mientras haya alguno en pantalla. Por eso `TRIAJE_GEOIP` y `TRIAJE_ASN` deben llevar «dbip» en el nombre, como en la plantilla. Las ediciones comerciales de DB-IP no exigen atribución.

7. Escribir el perfil del cliente

Todo lo que el MDR sabe de la red del cliente sale del perfil: los equipos, cuáles dependen de cuáles, dónde se contiene y qué se automatiza.

Quién puede: administración del MDR, con el inventario del cliente. Cada cambio pasa por el control de cambios del cliente.

Sección	Qué define
`activos`	Los equipos: IP, función, criticidad, servicios y **de quién dependen** (`depende_de`)
`topologia`	La cadena de contención: qué equipos se contienen y cuál es su cortafuegos (`gateway`)
`red`	Para el mapa: nodos extra (internet, switches), enlaces y zonas
`ip_gestion`, `redes_internas`	El plano de gestión, que nunca se corta, y las redes propias
`origenes_legitimos`, `terceros_confiables`	Quién no es atacante, y a quién no se bloquea sin un analista

Sección	Qué define
`continuidad`, `excepciones`	Qué se automatiza según el impacto, y los servicios que nunca se tocan solos
`rutas`	Adónde se deriva lo que no se contiene (por ejemplo, appsec)

Las dependencias deciden la cascada: si `app01` depende de `db01` y cae `db01`, `app01` cae con él. El MDR usa este dato para no aislar algo que tumbe servicios sin aprobación, y el mapa lo dibuja en la capa «dependencias».

Pasos

1. **Parte de la plantilla** `/opt/mdr/deploy/perfil.ejemplo.yml`. Describe una empresa con una DMZ, una red interna y dos cortafuegos, y explica cada apartado en sus comentarios.
2. **Nombra cada equipo como lo nombra el SIEM.** El MDR identifica el equipo atacado por el nombre de host que trae la alerta. Si en el SIEM se llama `srv-web01`, en `activos` también.
3. **Declara la cadena de contención** en `topologia`: cada servidor con su `gateway`, el cortafuegos que lo protege, y cada cortafuegos con el siguiente hacia internet. Sin ella, la contención sube a los cortafuegos perimetrales.
4. **Declara el plano de gestión** en `ip_gestion` y las redes propias en `redes_internas`. El MDR nunca corta el plano de gestión.
5. **Deja la automatización cerrada:** la plantilla trae `humano_siempre` en cada nivel de `continuidad`. Se abre después (sección 12).
6. **Revisa el perfil** antes de instalarlo:

   ```
   /opt/mdr/bin/mdr validar-perfil perfil-cliente.yml
   ```

   Responde «perfil sin avisos» o explica cada incoherencia; por ejemplo, un `gateway` que no existe o un equipo que depende de otro que no está en el inventario.
7. Instálalo en `/etc/mdr/perfil.yml` y **reinicia el servicio**: el perfil solo se lee al arrancar.

Ejemplo: en la plantilla, `web01` está en la DMZ detrás de `fw-dmz`. En `activos` lleva su IP, su criticidad y `depende_de: [app01]`; en `topologia`, `web01: {rol: host_victima, gateway: fw-dmz}`. `db01`, la base de datos, no está en `topologia`: una contención contra ella sube directamente al cortafuegos, sin tocar el equipo.

La postura de los equipos

La postura dice qué puertos tiene abiertos cada equipo del perfil. Con ella, el MDR distingue un ataque a un servicio expuesto, que contiene con confianza alta, de uno a un servicio cerrado, que es un falso positivo. **Sin postura, cada ataque queda con confianza 0,5**: por debajo de cualquier umbral, así que nada que dependa de la confianza (`automatica_si_confianza`) se ejecutará solo, y todo pasa por un analista.

Con autorización del cliente para escanear sus equipos:

```
sudo /opt/mdr/bin/mdr escanear
sudo systemctl restart mdr-triaje
```

Escanea con Nmap los 1000 puertos habituales de cada equipo de `activos` y escribe `/var/lib/mdr/postura.json`. `--puertos 22,443,5432` limita los puertos y `--equipos web01,app01`, los equipos. Un equipo que no responde no se escribe: queda como caso gris, nunca como «sin puertos». El MDR lee la postura al arrancar, de ahí el reinicio, que quita la pausa de la automatización si estaba puesta (sección 28). Repítelo cuando cambien los servicios de la red.

Añadir una red

Hay que completar cuatro sitios: sus equipos en `activos`; su cortafuegos y sus equipos en `topologia`, con su `gateway`; sus enlaces en `red.enlaces`, y la zona en `red.zonas`. Si solo se añaden los `activos`, los equipos salen en «Sin ubicar» y la escalada usa los cortafuegos perimetrales en vez del suyo. Una vez creada la zona, Conectividad ya puede dar de alta equipos en ella, y heredan el cortafuegos de sus vecinos.

Borrar un equipo

Hay que quitarlo de **todas** las secciones. Si se borra a medias, el MDR lo avisa al arrancar (en la Consola) y en la franja ámbar del mapa:

Si queda…	Qué pasa
en `topologia`, pero no en `activos`	Se sigue pintando y **se sigue conteniendo** en él
otros equipos que dependían de él	Su cascada desaparece
un `gateway` apuntando a un cortafuegos borrado	La escalada salta a los cortafuegos perimetrales («salto de respaldo»), pero **la cuarentena (AISLAR_NODO) de esos equipos deja de poder ejecutarse** hasta que se corrija

El historial del equipo borrado se conserva en Decisiones y en Trazas.

8. Conectar el SIEM

El MDR no detecta: refina lo que ya detectó el SIEM. Entiende las alertas del SIEM **Wazuh** (su `alerts.json`, una alerta JSON por línea), y hay dos formas de recibirlas.

> **Quién puede:** administración del MDR junto con quien administra el SIEM.

Forma	Cuándo	Qué configurar
Seguir el fichero	El `alerts.json` del SIEM es legible desde el equipo MDR	`TRIAJE_ALERTS` con su ruta, y permiso de lectura para `triaje`
Recibir por la red	El SIEM está en otra máquina (lo normal)	`TRIAJE_ESCUCHAR`, `TRIAJE_PERMITIR` y, mejor, TLS

Recibir por la red

1. En `/etc/mdr/triaje.env`, descomenta y ajusta:

```
TRIAJE_ESCUCHAR=0.0.0.0:6514
TRIAJE_PERMITIR=10.0.0.5
TRIAJE_TLS_CERT=/etc/mdr/tls/mdr.crt
TRIAJE_TLS_CLAVE=/etc/mdr/tls/mdr.key
TRIAJE_TLS_CA=/etc/mdr/tls/ca-siem.crt
```

`TRIAJE_PERMITIR` son las IPs del SIEM: sin ella, el servicio no arranca escuchando fuera de `127.0.0.1`. Con `TRIAJE_TLS_CA`, además, el SIEM debe presentar un certificado firmado por esa CA.

2. En el SIEM, un reenviador sigue el `alerts.json` y envía **una alerta JSON por línea** al puerto del MDR. Por ejemplo, con socat:

```
tail -n0 -F /var/ossec/logs/alerts/alerts.json | \
  socat -u - OPENSSL:equipo-mdr:6514,cert=siem.pem,cafile=ca-mdr.crt
```

   Ese reenviador lo mantiene el cliente, como un servicio más del SIEM.

3. Reinicia el MDR.

Nota: el receptor admite 64 conexiones (8 por IP) y cierra las que pasan 15 minutos sin enviar; el reenviador debe reconectar solo. Un proxy TLS delante hace que el MDR vea la IP del proxy, no la del SIEM, y la lista de IPs deja de servir.

Comprobar que el SIEM y el MDR se entienden

Antes de dar el sistema por bueno, pasa una muestra real de alertas del cliente por la herramienta:

```
/opt/mdr/bin/mdr validar-alertas muestra-alerts.json
```

Dice cuántas alertas sabe tratar el MDR, por familia, y qué reglas del SIEM quedan sin cubrir. Las que quedan sin cubrir el MDR no las contiene. Revisa también que los nombres de host de la muestra coinciden con los del perfil.

9. Dar acceso a los analistas

La consola pide un token a cada persona, y cada aprobación, reversión o cambio queda firmado con su nombre.

Quién puede: administración del MDR.

Rol	Quién es	Qué puede hacer
Analista	Cualquiera con un token de la consola	Ver todo, aprobar, rechazar, reclasificar, pausar, revertir, llevar casos y la Watchlist, editar Políticas y Conectividad
Administración del MDR	Quien administra el equipo MDR	Instalar y mantener el servicio, dar y quitar tokens, cambiar el perfil

Dar de alta a los analistas

1. Genera un token por persona: `openssl rand -hex 24`.
2. Añádelos a `/etc/mdr/triaje.env`, entre comillas simples:

```
TRIAJE_CONSOLA_OPERADORES='{"<token-de-ana>":"ana","<token-de-leo>":"leo"}'
```

3. Reinicia el servicio y entrega a cada analista su token por un canal seguro.

El túnel a la consola

La consola solo escucha en el propio equipo MDR. Cada analista necesita una cuenta SSH en el equipo MDR, sin `sudo`, y abre un túnel **con el mismo puerto** a los dos lados:

```
ssh -N -L 8787:127.0.0.1:8787 ana@equipo-mdr
```

Después abre **http://127.0.0.1:8787** en su navegador (sección 13).

Nota: el puerto local tiene que ser el mismo, 8787. La consola rechaza las peticiones que no vienen de su propio puerto: con `-L 9000:127.0.0.1:8787` se ve, pero no deja aprobar ni cambiar nada.

Las cuentas de los analistas solo necesitan el túnel. Conviene limitarlas a él en `/etc/ssh/sshd_config`, con un grupo `mdr-analistas` que las reúna:

```
Match Group mdr-analistas
    PermitOpen 127.0.0.1:8787
    AllowTcpForwarding local
    PermitTTY no
    X11Forwarding no
    ForceCommand /usr/sbin/nologin
```

Con esto entran con `ssh -N` y no tienen shell en el equipo MDR.

10. Dar al MDR acceso a los equipos

Para contener, el MDR entra por SSH en cada equipo con el usuario `triaje`, que solo puede ejecutar, por `sudo`, los comandos de su papel. Todo se hace desde la vista **Conectividad** de la consola (sección 25).

Quién puede: un analista, junto con quien administra cada equipo.

Antes de empezar

- En `/etc/mdr/triaje.env`, `TRIAJE_SSH_MODO=directo` y las rutas de `TRIAJE_SSH_CLAVE` y `TRIAJE_SSH_KNOWN_HOSTS` bajo `/var/lib/mdr/conector/`. Es lo que trae la plantilla.
- El equipo MDR alcanza por SSH la interfaz de gestión de cada equipo.

Pasos

1. **Genera la clave del conector.** En Conectividad, «Generar la clave del conector» (ed25519). Se crea en el equipo MDR; la privada no sale de allí. No hace falta reiniciar.
2. **Para cada equipo del perfil**, ábrelo en Conectividad:
    1. En «Papel y reglas», elige su papel (servidor, cortafuegos o puesto) y los servicios y cuentas que se pueden tocar. Las cuentas del sistema nunca se bloquean. Pulsa «Guardar y generar el paquete de corrección».
    2. Entrega el paquete a quien administra el equipo: un script, un playbook de Ansible o solo el sudoers. Lo ejecuta en el equipo como root: crea el usuario `triaje`, instala la clave pública y su sudoers en `/etc/sudoers.d/mdr-triaje`, e imprime la huella de la clave del equipo. No lleva secretos ni pide contraseñas.
    3. «Leer la clave del equipo», compara la huella con la que imprimió el paquete y «Fijar esta clave».
    4. Prueba la conexión. Debe quedar **verificada**.
3. **Para un equipo que no está en el perfil**, pulsa «+ Añadir equipo» y sigue el asistente: inventario (nombre, IP, zona, función, criticidad, interfaz y dependencias), papel y reglas, paquete de alta y, al final, «Leer la clave del equipo», «Coincide con la que imprimió el equipo» y «Dar de alta». Su zona tiene que existir ya en el perfil.

Nota: si una huella no coincide, **no la fijes**: compruébala con quien administra el equipo por otro canal. Una huella distinta puede ser una suplantación.

Nota: el formato «solo el sudoers» trae las rutas de los comandos de Debian y Ubuntu. En otro sistema, compruébalas con `command -v` antes de instalarlo. El script y el playbook las resuelven solos.

Qué ocurre después

Cada equipo verificado ya puede recibir contenciones. Uno dado de alta con el asistente entra además en el motor y en el mapa. Los que siguen «sin aprovisionar» aparecen en Conectividad; el MDR los deja en manos de un analista.

Nota: el MDR contiene por SSH en equipos Linux. Un cortafuegos o *appliance* sin SSH no se controla directamente: se contiene en el equipo Linux que hace de paso, o se deja en manos humanas.

11. Comprobar la instalación

Quién puede: administración del MDR, con un analista en la consola.

Pasos

1. **El servicio está sano:**

    ```
    curl -fsS http://127.0.0.1:8787/healthz
    ```

    Debe decir `"ok": true`. `ingesta_silencio_s` dice cuántos segundos lleva sin llegar una alerta.

2. **El perfil está limpio:** en la Consola no aparecen avisos del perfil al arrancar, y el mapa de Red no muestra la franja ámbar.
3. **Los equipos están verificados** en Conectividad.
4. **Una alerta de prueba llega.** Con permiso del cliente, provoca un evento controlado contra un equipo de prueba; por ejemplo, varios intentos de SSH fallidos desde una IP conocida. Debe salir en la Consola y, como todo está en `humano_siempre`, en Aprobaciones.
5. **La contención funciona.** Aprueba esa contención, comprueba en el equipo que la regla existe, y revírtela desde Contenciones activas.
6. **La traza verifica:** `sudo /opt/mdr/bin/mdr verificar-traza`.

Lista de comprobación

Comprobado	Qué
☐	`systemctl is-enabled mdr-triaje` dice `enabled`
☐	`/healthz` da `ok`
☐	`mdr validar-perfil` no da avisos
☐	La muestra de alertas cubre las familias esperadas (`mdr validar-alertas`)
☐	Cada analista entra con su token por el túnel
☐	Todos los equipos contenibles están verificados
☐	La alerta de prueba llegó, se contuvo y se revirtió
☐	La traza verifica, y `TRIAJE_TRAZA_CLAVE` está guardada fuera del equipo

12. Abrir la automatización poco a poco

El primer día todo espera a un analista. La automatización se abre cuando las decisiones del MDR se han visto acertar en la red del cliente, y **solo funciona con postura** (sección 7): sin ella, `automatica_si_confianza` no se cumple nunca.

> **Quién puede:** quien firma la autorización para actuar del cliente. El cambio lo hace la administración del MDR.

1. **Primeras semanas:** todo en `humano_siempre`. Los analistas aprueban o rechazan y el MDR deja constancia de cada decisión.
2. **Revisa** en el Informe cuántas propuestas se aprobaron tal cual y cuántas se rechazaron, por familia.
3. **Abre por impacto:** en el perfil, pasa `impacto_ninguno` a `automatica` y, después, `impacto_localizado` a `automatica_si_confianza`. Reinicia.
4. **Afina sin reiniciar** desde Políticas (sección 24): lo que se cambia allí solo puede **quitar** automatización, nunca añadirla, y queda firmado.

> **Nota:** las acciones con candado («nunca automática»), como aislar un equipo, esperan siempre a un analista, diga lo que diga el perfil.

Usar la consola

13. Entrar y moverse por la consola

Quién puede: cualquier analista con su token y el túnel abierto (sección 9).

Entrar

1. Abre **http://127.0.0.1:8787**. Aparece «Entrar a la consola».
2. Escribe tu token en «Token de operador».
3. Deja marcada «Mantener la sesión en esta pestaña» si no quieres que se pida al recargar. El token se guarda solo en esa pestaña, nunca en disco.
4. Pulsa «Entrar». Mientras se comprueba, el botón dice «Comprobando…».

Para salir, pulsa tu nombre en la cabecera y elige «Cerrar sesión».

Mensaje	Qué hacer
«El daemon no reconoce ese token.»	Revisa el token, o pide uno a la administración del MDR
«Demasiados intentos.»	Cinco tokens distintos fallidos en un minuto bloquean 30 s. Espera la cuenta atrás
«No hay respuesta del servicio MDR…»	El túnel está cerrado o el servicio parado. La pantalla reintenta sola cada 5 s
«Volver a entrar» (sobre la vista)	Tu token dejó de valer mientras trabajabas. Al entrar sigues donde estabas

El menú lateral

Grupo	Entradas
—	«Panel»
Operar	«Consola», «Aprobaciones», «Contenciones activas», «Decisiones»
Investigar	«Incidentes», «Red», «Ubicaciones», «Watchlist», «Trazas»
Informar	«Informe»
Configurar	«Políticas de respuesta», «Conectividad», «Estado de servicios»

Las señales del menú dicen dónde hay algo:

Señal	Qué significa
Número ámbar en «Aprobaciones»	Decisiones que esperan a un analista. Es lo que pide acción
Números en «Contenciones activas» e «Incidentes»	Bloqueos vigentes y campañas sin resolver

Señal	Qué significa
Punto verde en «Consola»	El registro vivo está llegando
Icono rojo en «Estado de servicios»	Un servicio caído, el conector sin configurar o un equipo con problemas de conexión o configuración. Al pasar el ratón se ve el motivo

El botón del pie pliega el menú a iconos; la consola lo recuerda.

La cabecera

- **«datos en vivo»** o **«sin conexión con el daemon»**. Sin conexión, cada vista sigue mostrando lo último que recibió, con la hora.
- **La campana** activa los avisos del navegador. Cuando llega una decisión **nueva** que espera aprobación, el navegador lo notifica aunque estés en otra pestaña, con un pitido corto. La pestaña muestra siempre el número de pendientes: «(3) MDR — consola de triaje».
- **Sol o luna:** tema claro u oscuro.
- **Tu nombre:** cómo firmas, desde cuándo, y «Cerrar sesión».

Con la automatización en pausa, una banda roja arriba avisa de que «toda contención automática espera aprobación humana». Su botón «Gestionar» lleva a Contenciones activas (sección 17).

14. El Panel

El Panel responde a dos preguntas al llegar: «¿funciona todo?» y «¿qué me toca?».

Quién puede: cualquier analista.

La línea de salud

Una frase y cuatro indicadores:

Indicador	Qué mide	Cuándo preocupa
Servicios	Cuántos servicios del cliente están en pie (sección 29)	Si alguno cae
Ingesta	Cuándo llegó la última alerta del SIEM	Ámbar a los 2 min, rojo a los 15
Traza	Si la cadena está «íntegra» o «rota»	Si está rota
Conector	Cuántos equipos están verificados o con problemas	Si hay problemas

Las cifras del día

Decisiones de hoy (comparadas con ayer a la misma hora), contenidas en automático, las que esperan a un humano (con cuántas fuera del SLA), incidentes abiertos y ruido evitado. Las que piden acción se pueden pulsar.

«Te toca»

Lo que necesita a un analista, por orden de urgencia:

- **Las aprobaciones más cercanas a vencer el SLA**, con su barra de tiempo y el botón «Revisar».
- **Equipos sin acceso:** «El MDR no tiene acceso a X desde las HH:MM».
- **Campañas sin responsable**, con «Asignarme».
- **Contenciones fallidas**, con su causa en lenguaje claro. Lo que **puede ser un ataque** va primero y en rojo, como «Posible ataque en X», aunque la escalada lo haya contenido en otro equipo.

Debajo están la actividad de las últimas 24 horas, qué se está atacando, los equipos más atacados y las últimas decisiones, con enlaces a sus vistas.

15. Cómo resolver las aprobaciones

Aquí esperan las decisiones que el perfil del cliente no deja ejecutar solas: tocan un servicio, un equipo crítico o son acciones que nunca se automatizan. Es el trabajo principal del analista.

> **Quién puede:** cualquier analista. La decisión queda firmada con su nombre.

Antes de empezar

- **El SLA es de 15 minutos** desde que la decisión entra en la cola (se ajusta con `TRIAJE_SLA_SEG`).
- Activa la campana si quieres que el navegador te avise de cada decisión nueva.

Leer la lista

Cada fila muestra la gravedad (de P1 a P4), «equipo · familia → ACCIÓN», las marcas «cascada» (la acción tumbaría otros servicios) y «escalada» (es un salto al cortafuegos), la IP de origen y su país, «sigue atacando +N» si llegaron repeticiones mientras esperaba, y la edad con su barra de SLA.

Para…	Usa
Filtrar	«Todas», «Fuera de SLA», «Críticas», «Con cascada», «Sigue atacando»
Ordenar	Más recientes, más antiguas, urgencia o gravedad
Agrupar	Por país, por campaña /24, por equipo, por familia o por gravedad

Pasos

1. **Elige una decisión** de la lista. A la derecha se abre el inspector.
2. **Lee «Si apruebas».** Qué se ejecuta, contra quién y con qué consecuencia. Si hay cascada, la lista de equipos que caerían.
3. **Lee «Por qué lo propone el motor».** La clase, la confianza, por qué necesita a un humano y la técnica ATT&CK, y debajo lo que ya pasó con ese origen.
4. **Si quieres, escribe una nota** en «Nota para la traza…». Se guarda en el caso.
5. **Decide:**

Botón	Tecla	Qué hace
«Aprobar»	A	Ejecuta la acción. Con cascada, pide confirmar «Aprobar igualmente»
«Rechazar»	R	No ejecuta nada. La amenaza queda registrada
«Reclasificar»	C	La clase estaba mal: eliges la correcta. No ejecuta nada y queda como corrección del motor

Tras decidir, el inspector salta a la siguiente pendiente.

Ejemplo: llega «web01 · acceso_credenciales → BLOQUEAR_IP», de 203.0.113.9. «Si apruebas» dice que se bloquea esa IP en web01, sin servicios afectados. La pulsas «Aprobar» (o la tecla A); en la Consola aparece el comando `iptables` y, segundos después, «verificada».

Decidir en bloque y con el teclado

- **Atajos:** J y K (o las flechas) para moverte, X para marcar. No actúan mientras escribes ni con un diálogo abierto.
- **En bloque:** marca varias y usa «Aprobar las N» o «Rechazar las N». **Aprobar** en bloque pide confirmación; **rechazar** en bloque, no.

Qué ocurre después

- La decisión desaparece de la cola y queda en Decisiones con tu nombre.
- **Escaladas.** Si apruebas y el equipo atacado no responde, el MDR intenta contener en su cortafuegos. Si ese salto también necesita a un humano, aparece como una aprobación nueva con la marca «escalada», que solo tiene Aprobar y Rechazar.
- **«No se aplicó el veredicto»** significa que otro analista la resolvió antes o que la decisión cambió. Mira la cola de nuevo.

16. Cómo seguir la Consola

La Consola es el registro vivo del MDR: incidentes, decisiones, cada comando que se ejecuta por SSH, verificaciones, escaladas, reversiones y avisos. Guarda las últimas 1000 líneas.

Quién puede: cualquier analista.

- **Filtros:** «Todo», «Decisiones», «Incidentes», «Ejecución», «Avisos», y un campo para filtrar por texto.
- **Desplazamiento automático:** se pausa si subes a leer y se reanuda al bajar al final.

Símbolo	Significado
⚠	Incidente nuevo
▶	Orden ejecutada en un equipo, con su comando exacto
✔	Verificada: la contención está puesta
✗ … NO verificada / ✗ … no se ejecutó	La contención no quedó: dice dónde, por qué y qué hacer

Símbolo	Significado
· … evidencia:	La salida real de SSH o sudo que lo prueba
⇧	Escalada: dónde contuvo o en qué equipos falló, y «POSIBLE ATAQUE» si lo es
↶	Reversión
✓ □ ↻	Veredicto de un analista
☰	Cambio en un caso
↩	Repetición suprimida (ruido)
↺	Actividad propia del MDR, su propio SSH visto por el SIEM
□	Pausa de la automatización
[aviso]	Aviso del sistema, por ejemplo «el MDR no tiene acceso a X»

Ejemplo: tras aprobar el caso de web01 verás, en este orden, «▶ … BLOQUEAR_IP en web01 (192.0.2.10): iptables -A INPUT -s 203.0.113.9 -j DROP» y «✔ … verificada — contenida en web01».

17. Cómo pausar la automatización y revertir contenciones

«Contenciones activas» lista lo que está bloqueado **ahora**: qué se bloqueó, a quién protege, quién lo decidió («automática», «vía escalada» o «aprobó Fulano»), su antigüedad y **cuántos intentos paró**. Una contención con intentos parados está sirviendo. El inspector muestra la gráfica de intentos antes y después del bloqueo, la regla exacta y el comando que la quita.

Quién puede: cualquier analista. Cada reversión queda en la traza con su nombre.

Pausar la automatización

1. Pulsa el interruptor «Automatización». **No pide confirmación.**
2. Desde ese momento, **toda** contención nueva espera a un analista. Arriba aparece la banda roja.
3. Para reanudar, vuelve a pulsarlo.

Nota: pausar **no** retira las contenciones que ya están puestas, y la pausa se pierde si se reinicia el servicio.

Revertir

Botón	Qué hace
«Revertir…»	Quita una contención. Pide confirmación
«Revertir y vigilar…»	La quita y añade la IP a la Watchlist
«Revertir las N…»	Las seleccionadas

Botón	Qué hace
«Revertir todas (N)…» / «Revertir las de más de 7 días (N)…»	En masa. **Hay que escribir el número de contenciones** para habilitar el botón

Revertir es real: el MDR quita la regla en el equipo y lo anota. Si el origen sigue intentándolo, volverá a llegar.

> **Ejemplo:** el bloqueo de 203.0.113.9 en web01 muestra «12 intentos parados» en el día. Si fuera un falso positivo (una IP de un socio, por ejemplo), «Revertir y vigilar…» lo quita y deja la IP marcada en la Watchlist.

18. Cómo leer una decisión

«Decisiones» es el historial de lo que decidió el motor y en qué acabó.

> **Quién puede:** cualquier analista.

Encontrarla

- **La franja de arriba** filtra al pulsarla: decisiones, contenidas en automático, pasaron por un analista, corregidas por el analista, frenadas por la política, contención fallida.
- **El buscador** encuentra por equipo, IP, identificador o país; el selector, por clase.
- **Filtros:** «Pendientes», «Falsos positivos», «Decididas por mí»… y la casilla «Incluir registros del sistema» para ver reversiones y supresiones.

Color del desenlace	Desenlaces
Verde	contenida
Rojo	fallida, vetada
Ámbar	rechazada, pendiente, degradada
Violeta	reclasificada
Gris	enrutada, falso positivo, no soportada, sin acción

Leer el detalle

El detalle se lee como una historia de seis pasos: la alerta del SIEM, la clasificación, la propuesta del motor, la política del cliente («automática», «retenida — espera tu aprobación», «degradada», «vetada»), el analista y la ejecución, con dónde quedó contenida y el comando exacto.

Si la contención falló, cada intento lleva su causa en lenguaje claro y la evidencia debajo, por ejemplo «intento en app01: equipo sin aprovisionar — dalo de alta o fija su clave del host en Conectividad». El anexo E tiene todas las causas.

> **Nota:** las causas marcadas **POSIBLE ATAQUE** (la clave del equipo cambió, alguien deshizo la contención, un equipo que funcionaba dejó de hacerlo) no son un problema de configuración. Compruébalo por otro canal antes de tocar nada.

«Salto de respaldo» significa que el perfil tenía la cadena de cortafuegos rota y la escalada siguió hasta el perímetro: hay que corregir el perfil (sección 7).

El detalle incluye también la justificación, con los datos en que se apoya, el origen y «Qué hacer después»: la recomendación y los pasos del runbook. Desde aquí se abren el grafo del incidente, el perfil del atacante, la contención y la prueba en Trazas.

19. Cómo llevar un incidente

Un incidente agrupa los ataques de un mismo bloque de IPs (/24), la campaña. Cada uno muestra su estado («Nuevo», «En revisión», «Resuelto»), si está activo ahora (punto rojo: atacó en la última hora) y su responsable. El panel del caso cuenta la historia del ataque: contra qué equipos, cuántas decisiones y bloqueos, y la cronología.

Quién puede: cualquier analista. Cada cambio queda en la traza con su nombre y la hora.

1. En «Incidentes», elige la campaña. Por defecto se ven las abiertas.
2. Pulsa «asignarme» para hacerte responsable.
3. Pasa el estado a «En revisión» y escribe lo que vas viendo en «Nota»; «Guardar en el caso».
4. Para cerrarlo, escribe por qué y pulsa «Resolver con esta nota».

Ejemplo: la campaña 203.0.113.0/24 tiene una decisión contenida contra web01. Te la asignas, compruebas en «Contra qué equipos» que no tocó a nadie más y la resuelves con la nota «Fuerza bruta contenida en el host; sin más actividad del bloque».

El historial de un caso no se puede borrar.

20. Cómo leer el mapa de la red

«Red» dibuja la red del cliente con la actividad de cada equipo. Se lee de arriba abajo: el carril de internet y los orígenes que más atacan, el tronco de cortafuegos y las zonas, cada una colgada del cortafuegos que la protege. Una red detrás de su propio cortafuegos sale en su propia rama.

Quién puede: cualquier analista.

Símbolo	Estado del equipo
⚠	atacado
▯	espera tu decisión
✓	contenido
⚠ (ámbar)	caería en cascada
↗	origen de ataques
✕	caído

Símbolo	Estado del equipo
○	sin actividad

Capas y acciones

- **«ataques»:** flechas rojas desde el origen; el grosor es el volumen.
- **«cascada»:** en ámbar, de un equipo caído a los que dependen de él.
- **«dependencias»:** en violeta, quién depende de quién. Dentro de una zona se dibuja como un arco por la derecha de la columna.
- **«solo con actividad»** pliega las zonas tranquilas; una zona también se pliega pulsando su píldora.
- **El buscador** encuentra un equipo por nombre o IP. Al elegirlo, se atenúa lo que no tiene relación y se abre su ficha: riesgo, ataques recibidos y contenidos, atacantes, eventos y enlaces.

Nota: los equipos y las dependencias del mapa salen del **perfil del cliente**, no de Conectividad. Si el perfil tiene algo roto, una franja ámbar encima del mapa lo lista (sección 7).

Perfil del atacante. Se abre pulsando una IP: su riesgo, los equipos que atacó, su actividad y su línea de tiempo. «DNS inverso: Resolver» solo consulta si lo pides y solo para IPs públicas.

21. Ubicaciones y Watchlist

Quién puede: cualquier analista.

Ubicaciones muestra en un mapamundi de dónde vienen los ataques, por país. La geolocalización no consulta servicios externos: usa la base de países instalada en el MDR (sección 6). Si no hay base, un aviso lo dice y los orígenes públicos van a la tabla como «Pública (sin base de geolocalización)». Tres métricas: «En curso» (aún no contenidos), «Total» y «Mitigados». Al pulsar un país, «En curso» lleva a Aprobaciones de ese país; las otras dos, a Decisiones. Las IPs internas o sin geolocalizar solo salen en la tabla.

Watchlist es tu lista de indicadores sospechosos: una IP o un bloque /24, con una nota. **Es solo una anotación**: no cambia ninguna decisión del motor. Las IPs vigiladas salen marcadas con ⚑ en la Red y en el perfil del atacante. «Quitar» no pide confirmación.

22. Cómo comprobar la integridad de la traza

«Trazas» es el registro auditable: cada decisión, veredicto, reversión y cambio de caso, encadenado por hash. Si alguien altera un registro, la cadena se rompe en ese punto y la consola lo dice.

Quién puede: cualquier analista.

1. Mira la franja de arriba: «Cadena íntegra» o «Cadena rota en el registro #N». Se comprueba cada 30 segundos; «Verificar ahora» la comprueba en el momento.
2. Lee la marca de cada fila: ✓ verificado, ✗ alterado, ⚠ posterior a una rotura.

3. Pulsa una fila para ver el registro, su «Causa del fallo» si la tiene, y la prueba de la cadena (el hash anterior y el suyo). «Copiar el registro (JSON)» lo copia para auditarlo fuera.

Si la cadena se rompe, el inspector abre directamente el registro alterado. Fuera de la consola, la administración la comprueba con `sudo /opt/mdr/bin/mdr verificar-traza`.

23. Cómo sacar el informe en PDF

«Informe» resume un periodo: indicadores (tasa de falsos positivos, resuelto sin humano, escalado a humano, tiempo medio de respuesta, dentro del SLA, ruido evitado), rankings de equipos, familias, orígenes y analistas, la cobertura MITRE ATT&CK y un resumen redactado.

Quién puede: cualquier analista.

El modo «En vivo» no se exporta: elige un periodo cerrado («Este mes», «Este año» o «Rango…»).

1. Elige el periodo.
2. En «Qué incluir», marca las secciones. Por defecto van todas salvo el anexo con el detalle de cada decisión.
3. Rellena «Para» con el cliente y el área destinataria. Debajo verás el nombre del archivo, por ejemplo `Informe-MDR-2026-11`.
4. Pulsa «Vista previa del PDF». Se abre el documento en hojas A4: portada, comparación con el periodo anterior, recomendaciones e integridad de la traza.
5. Pulsa «Guardar PDF» y, en el diálogo de impresión del navegador, elige guardar como PDF.

Ejemplo: el informe de noviembre incluye la campaña 203.0.113.0/24 entre los orígenes, web01 entre los equipos atacados y su contención dentro del SLA.

Configurar

24. Políticas de respuesta

Decide qué respuestas se ejecutan solas y cuáles esperan a un analista, sin tocar el perfil ni reiniciar.

Quién puede: cualquier analista. Cada clic se guarda al momento, **sin confirmación**, y queda en la auditoría con su nombre.

- **«Por tipo de ataque».** Cada familia muestra su acción y un selector AUTO / HUMANO. Las que llevan candado («freno duro / nunca automática») no se pueden poner en automático; las que «se trían y enrutan» no tienen acción. «detalle» muestra el impacto, los vetos y el runbook.
- **«Por zona y dispositivo».** Postura por zona (AUTO o HUMANO; el plano de gestión no se edita) y por equipo (HEREDA, AUTO o HUMANO), con su criticidad y cuántos equipos caerían en cascada.

Nota: si la familia **o** la zona está en HUMANO, prevalece HUMANO. Lo que se edita en la consola solo puede **quitar** automatización respecto al perfil; nunca añadirla. Se conserva al reiniciar.

25. Conectividad

Gestiona cómo entra el MDR en cada equipo. Cómo dar de alta los equipos está en la sección 10; aquí, lo que se ve y lo que se hace después.

Quién puede: cualquier analista.

Nota: es una vista delicada. La **clave privada del conector nunca llega al navegador**: solo se ven la pública y las huellas. **Ninguna clave del host se acepta sola**: siempre hay que confirmar que la huella coincide con la que imprimió el equipo.

Lo que se ve

- **La franja de permisos**, con lo que puede hacer tu sesión.
- **La clave del conector**, con su huella y «Copiar clave pública».
- **Las cifras:** equipos contenibles, conexión verificada, clave del host cambiada, sin aprovisionar.
- **La tabla de equipos**, con su papel, el estado de la conexión, si su sudoers coincide con su papel y su clave del host.

Estado	Significado
verificada	La última prueba pasó. Con más de 24 h, «conviene volver a probar»
bloqueada	**La clave del host cambió.** Puede ser una suplantación

Estado	Significado
privilegio de más	sudo permite más de lo que su papel necesita
sin aprovisionar	No acepta la clave del conector o falta su clave del host
sin acceso / fallo	No se pudo conectar, o el comando falló
sin probar / alta pendiente	Aún no se ha probado / se está dando de alta

El aviso rojo encima del estado aparece cuando una **contención real** falló en ese equipo: «la última contención falló», «posible ataque» o «sin acceso». Solo resta confianza: una prueba verde anterior no lo tapa. Se quita con una contención correcta o con una prueba nueva que pase.

Un equipo que ya existe

- **«Fijar la clave del host»**, para uno que nunca se conectó: «Leer la clave del equipo», compara la huella y «Fijar esta clave».
- **«Clave del host cambiada»:** muestra la fijada frente a la que presenta ahora. **Compruébalo por otro canal** antes de «Aceptar la nueva clave…».
- **«Papel y reglas»:** cambia el papel o quítalo. Si alguien tocó el sudoers del equipo, verás lo que **sobra** (rojo) y lo que **falta** (ámbar), y podrás «Generar paquete de corrección».
- **«Cómo entra el conector»:** puerto y usuario. «Probar y guardar» solo guarda si la prueba pasa.

> **Nota:** la consola solo quita altas pendientes y papeles. Un equipo ya dado de alta lo quita la administración (sección 32).

Rotar la clave del conector

Ningún equipo se queda sin acceso por el camino:

1. «Rotar la clave del conector…» e «Iniciar: generar el par nuevo».
2. «Añadir y probar en todos»: la clave nueva entra en cada equipo junto a la vieja y se prueba.
3. «Retirar la clave vieja…» (pide confirmación; desde ahí ya no se puede cancelar) y «Finalizar».

> **Ejemplo:** si la contención en web01 hubiera fallado con «equipo inalcanzable», su fila mostraría encima «la última contención falló · equipo inalcanzable · hace 1 min». Si el equipo estaba verificado, diría «posible ataque»: alguien pudo cortar el acceso del SOC.

26. Estado de servicios

Solo es de consulta.

> **Quién puede:** cualquier analista.

- **«MDR propio»:** si el lazo de decisión está vivo, cuándo llegó la última alerta del SIEM y cuántas se procesaron.
- **«Conector»:** cuántos equipos están verificados o con problemas, con el enlace a Conectividad.

- **Los servicios del cliente**, con los caídos primero. Un servicio caído dice «afecta a …» los que dependen de él; uno que depende de un caído, «responde, pero X está caído». Necesita el monitor de servicios del cliente (sección 29); sin él, «Sin datos del monitor de servicios».
- Si la muestra del monitor tiene más de un minuto, la vista avisa de que es lo último que se supo.

El icono de esta vista en el menú se pone **rojo** con cualquiera de esos problemas.

27. Recortes ante fallos de contención

Cinco ajustes que ahorran conexiones que no podían servir cuando un equipo falla. No cambian qué se contiene. Están **apagados por defecto** y se encienden con `=1` en `/etc/mdr/triaje.env`, reiniciando el servicio.

Quién puede: administración del MDR.

Variable	Efecto
`TRIAJE_FALLO_RAPIDO`	Si la primera conexión ni siquiera entra en el equipo, no se repite contra él. La escalada sigue igual
`TRIAJE_PRECHECK_APROVISIONADO`	No intenta en un equipo que la consola sabe sin clave del host. Escala, o queda fallida con su motivo
`TRIAJE_ESCALADA_SOLO_APROVISIONADOS`	Salta los cortafuegos de escalada sin aprovisionar y lo anota («salto omitido»)
`TRIAJE_MEMORIA_FALLOS`	Tras 3 fallos de acceso seguidos a un equipo en 5 minutos, deja de intentar en él y escala directo. Avisa una vez («el MDR no tiene acceso a X») y lo reprueba cada 60 s sin sudo
`TRIAJE_ACCION_NO_EJECUTABLE`	Si la prueba de Conectividad de las últimas 24 h dice que falta la regla de esa acción en el sudoers, no la intenta

Nota: ninguno se activa ante una clave del host cambiada ni ante una contención deshecha: pueden ser un ataque y se quieren ver en cada intento.

Mantener

28. Arrancar, parar y ver el registro

Quién puede: administración de sistemas del equipo MDR.

Qué	Cómo
Estado	`systemctl status mdr-triaje`
Registro en vivo	`journalctl -u mdr-triaje -f`
Reiniciar (tras cambiar el perfil o `triaje.env`)	`sudo systemctl restart mdr-triaje`
Parar	`sudo systemctl stop mdr-triaje`

Al reiniciar, el MDR recupera de la traza las contenciones activas, y conserva las políticas y el inventario. **Se pierden** la pausa de la automatización, el estado operativo de Conectividad y la memoria de fallos, que viven en memoria.

Nota: parar el servicio **no** quita las contenciones puestas: siguen en los equipos. Para quitarlas, revírtelas desde la consola antes de parar.

29. Vigilar el MDR y los servicios

Quién puede: administración de sistemas del equipo MDR.

El propio MDR

Un monitor local debe avisar si el MDR se cuelga o si el SIEM deja de enviar. `/healthz` da las dos cosas: `ok` dice si el MDR está vivo y `ingesta_silencio_s` , cuánto lleva sin alertas. Por ejemplo, en `/etc/cron.d/mdr-salud` , una sonda cada minuto que avisa al syslog:

```
* * * * * root curl -fsS http://127.0.0.1:8787/healthz | python3 -c 'import sys,json;
d=json.load(sys.stdin); sys.exit(0 if d["ok"] and (d["ingesta_silencio_s"] or 0) < 900 else
1)' || logger -p daemon.err "MDR: lazo no sano o ingesta en silencio"
```

Ajusta los 900 segundos al tráfico normal del cliente: una red tranquila puede pasar horas sin alertas.

Los servicios del cliente

Estado de servicios y el indicador «Servicios» del Panel muestran si los servicios del cliente están en marcha. El MDR no los sondea: lee lo que publica el monitor de servicios del cliente en un fichero, una línea JSON por muestra:

```
{"t": "2026-11-09T10:00:05Z", "estados": {"web01": "ok", "app01": "caido"}}
```

Indica su ruta en `TRIAJE_SALUD` y reinicia. Los nombres deben ser los del perfil, para que la vista muestre de quién depende cada uno, y `triaje` debe poder leer el fichero.

30. Copias de seguridad y retención

Quién puede: administración de sistemas del equipo MDR.

Qué copiar	Por qué
`/var/lib/mdr`	La traza (la evidencia), lo editado en la consola, el inventario operativo y la clave del conector
`/etc/mdr`	La configuración y el perfil
`TRIAJE_TRAZA_CLAVE`, aparte	Sin ella, la traza firmada no se puede verificar

Nota: la copia contiene la clave privada del conector y los tokens de los analistas. Trátala como un secreto.

Fichero de `/var/lib/mdr`	Contenido
`trazas-*.jsonl`	La traza encadenada. Al reiniciar, el MDR recupera de aquí las contenciones activas
`politica-operativa.yml`, `politica-auditoria.jsonl`	Lo editado en Políticas, y quién cambió qué
`conectividad-operativa.yml`, `conectividad-auditoria.jsonl`	Usuario y puerto por equipo, y cada prueba y cambio en Conectividad
`conectividad-pruebas.json`, `conectividad-rotacion.json`	La última prueba de cada equipo y la rotación de clave en curso
`inventario-operativo.yml`	Los equipos dados de alta desde la consola y sus papeles
`watchlist.json`	La Watchlist
`conector/`	La clave del conector y las claves de host fijadas

La traza es **un solo fichero que crece** (`TRIAJE_SALIDA`), y no se recorta: es la evidencia y de ella se recuperan las contenciones activas al reiniciar. Vigila su tamaño (`du -h /var/lib/mdr`) y consérvala en las copias. `mdr podar-trazas` solo sirve para las trazas antiguas que queden en el directorio, por ejemplo tras cambiar la clave de la traza (sección 33); nunca toca la que está en uso.

31. Actualizar el MDR

Quién puede: administración de sistemas, con el paquete de la versión nueva.

Pasos

1. Si la actualización cambia el comportamiento, pausa la automatización en la consola.
2. Para el servicio y guarda la versión actual:

```
sudo systemctl stop mdr-triaje
sudo mv /opt/mdr /opt/mdr.anterior
```

3. Instala la nueva y arranca:

```
sudo mkdir -p /opt/mdr && sudo tar -xzf mdr-<versión>.tar.gz -C /opt/mdr
sudo systemctl start mdr-triaje
```

4. Comprueba el arranque y `/healthz` (sección 11). Los analistas recargan la consola en el navegador.
5. Si las notas de la versión dicen que cambiaron los permisos de algún papel, Conectividad marca los equipos afectados: genera su paquete de corrección y que su administrador lo ejecute.

Actualizar las bases de países y de organizaciones

DB-IP publica bases nuevas cada mes. Descárgalas e instálalas igual que la primera vez (sección 6), con `mdr instalar-geoip` y `mdr instalar-asn`, y reinicia.

Si algo falla

Vuelve atrás: para el servicio, `sudo rm -rf /opt/mdr && sudo mv /opt/mdr.anterior /opt/mdr`, y arranca. La configuración y el estado no se tocan al actualizar.

32. Cambiar el perfil

Cambiar el perfil cambia lo que el MDR puede hacer en el cliente. Cada cambio pasa por el control de cambios acordado (sección 4).

Quién puede: administración del MDR, con la aprobación del cliente.

1. Edita una copia y revísala con `mdr validar-perfil` (sección 7).
2. Instálala en `/etc/mdr/perfil.yml` y reinicia el servicio.
3. Comprueba en la Consola que el arranque no da avisos.

Nota: un equipo dado de alta desde la consola se quita borrándolo de `/var/lib/mdr/inventario-operativo.yml` y reiniciando.

33. Rotar claves y tokens

Quién puede: administración del MDR; la clave del conector, un analista desde Conectividad.

Qué	Cómo
Clave del conector	Desde Conectividad (sección 25). Ningún equipo se queda sin acceso
Token de un analista	Cámbialo en `TRIAJE_CONSOLA_OPERADORES` y reinicia. Para dar de baja a alguien, quita su entrada
Clave de la traza (`TRIAJE_TRAZA_CLAVE`)	**No la cambies** sobre la misma traza: lo ya firmado dejaría de verificar. Si hay que cambiarla, revierte antes las contenciones y empieza una traza nueva con otro `TRIAJE_SALIDA`

34. Desinstalar

Quién puede: administración de sistemas, con el visto bueno del cliente.

Pasos

1. **Revierte todas las contenciones** desde la consola. Parar el servicio no las quita.
2. Para y quita el servicio:

```
sudo systemctl disable --now mdr-triaje
sudo rm /etc/systemd/system/mdr-triaje.service && sudo systemctl daemon-reload
sudo rm -rf /opt/mdr /etc/mdr
```

3. **Conserva o archiva `/var/lib/mdr`** según la política de evidencias del cliente; contiene la traza. Después, `sudo userdel triaje`.
4. **En cada equipo**, quien lo administra quita el acceso del MDR:

```
sudo rm /etc/sudoers.d/mdr-triaje
sudo userdel -r triaje
```

Anexos

Anexo A. El fichero triaje.env

La plantilla es `/opt/mdr/deploy/triaje.env.ejemplo`. Una variable por línea, los comentarios en su propia línea y el JSON entre comillas simples.

Variable	Valor
`TRIAJE_ALERTS`	Ruta del `alerts.json` del SIEM. Sin uso si se recibe por red
`TRIAJE_PERFIL`	`/etc/mdr/perfil.yml`
`TRIAJE_HALLAZGOS`	`/var/lib/mdr/postura.json`. Lo escribe `mdr escanear` (sección 7)
`TRIAJE_SALIDA`	Ruta **fija** de la traza, en `/var/lib/mdr`
`TRIAJE_WEB_PUERTO`	`8787`
`TRIAJE_ESCUCHAR`, `TRIAJE_PERMITIR`	Recibir del SIEM por red, y desde qué IPs
`TRIAJE_TLS_CERT`, `TRIAJE_TLS_CLAVE`, `TRIAJE_TLS_CA`	TLS del receptor; con la CA, exige certificado al SIEM
`TRIAJE_SSH_MODO`	`directo`
`TRIAJE_SSH_USUARIO`	`triaje`
`TRIAJE_SSH_CLAVE`, `TRIAJE_SSH_KNOWN_HOSTS`	Bajo `/var/lib/mdr/conector/`
`TRIAJE_TRAZA_CLAVE`	Firma de la traza. Recomendada: sin ella, el arranque avisa «SIN firma HMAC»
`TRIAJE_ANCLA`	`host:puerto` del syslog del SIEM, para anclar la traza
`TRIAJE_CONSOLA_OPERADORES`	`'{"token":"nombre", …}'`: un token por analista
`TRIAJE_GEOIP`	`/var/lib/mdr/dbip-country-lite.csv.gz`. La base de países (sección 6)
`TRIAJE_ASN`	`/var/lib/mdr/dbip-asn-lite.csv.gz`. La base de organizaciones (sección 6)
`TRIAJE_SALUD`	Fichero del monitor de servicios del cliente (sección 29)
`TRIAJE_SLA_SEG`	Plazo de respuesta del analista, en segundos (900 por defecto)
`TRIAJE_RDNS`	`1` permite el DNS inverso de IPs públicas desde el perfil del atacante
Recortes ante fallos	Los cinco de la sección 27

Nota: no fijes `TRIAJE_SSH_MODO=password`, `TRIAJE_CONECTIVIDAD_ABIERTA`, `TRIAJE_POLITICA_ABIERTA` ni `TRIAJE_CORS_DEV`. Son modos de prueba que quitan protecciones: entrar con contraseña, o cambiar Conectividad y Políticas sin un analista identificado.

Anexo B. La herramienta mdr

`/opt/mdr/bin/mdr` reúne las tareas de administración. Lee `/etc/mdr/triaje.env` si puede, así que, ejecutada con `sudo`, usa las mismas rutas y la misma clave de la traza que el servicio.

Orden	Qué hace
`mdr validar-perfil [perfil.yml]`	Revisa el perfil (por defecto, el de `TRIAJE_PERFIL`). Sale con error si hay avisos
`mdr validar-alertas <muestra.json>`	Cuenta qué alertas de una muestra del SIEM sabe tratar el MDR y qué reglas quedan sin cubrir
`mdr escanear [--puertos …] [--equipos …]`	Escanea con Nmap los equipos del perfil y escribe la postura. Después, reinicia el servicio
`mdr instalar-geoip <fichero.csv.gz>`	Comprueba la base de países descargada y la instala en `TRIAJE_GEOIP`. Después, reinicia el servicio
`mdr instalar-asn <fichero.csv.gz>`	Lo mismo con la base de organizaciones (ASN), en `TRIAJE_ASN`
`mdr verificar-traza [traza.jsonl]`	Comprueba que la traza no se ha alterado (por defecto, la de `TRIAJE_SALIDA`)
`mdr podar-trazas <directorio> --max N`	Dice qué trazas antiguas borraría; con `--aplicar`, las borra. También `--max-dias D` y `--excepto <traza>`
`mdr ayuda`	La lista de órdenes

Anexo C. Puertos y flujos de red

Desde	Hacia	Puerto	Para qué
SIEM	Equipo MDR	TCP 6514 (configurable)	Alertas, si se reciben por red
Equipo MDR	Gestión de cada equipo	TCP 22 (o el de Conectividad)	Contener, verificar y revertir
Equipo MDR	SIEM	El de su syslog	Anclar la traza, si `TRIAJE_ANCLA` está fijada
Analistas	Equipo MDR	TCP 22	El túnel a la consola
Equipo MDR, SIEM y equipos	Servidor NTP	UDP 123	Un reloj común

La consola (`8787`) **no** se abre en el cortafuegos: solo escucha en `127.0.0.1`.

Anexo D. Familias de ataque y su respuesta

Familia	Respuesta	¿Puede ser automática?
acceso_credenciales (fuerza bruta)	BLOQUEAR_IP en el equipo; si falla, en el cortafuegos	Sí, si el perfil lo permite y la confianza llega al umbral
reconocimiento (escaneos)	BLOQUEAR_IP	Igual que la anterior
servicio_expuesto	BLOQUEAR_IP si el servicio está expuesto; si no, falso positivo	Igual que la anterior
explotacion_conocida	Se tría y se **enruta** al equipo de appsec; no se contiene	—
abuso_de_cuenta	FORZAR_CAMBIO_PASS (bloquea la cuenta)	**Nunca**
integridad_fichero	AISLAR_NODO (cuarentena en el cortafuegos de borde)	**Nunca**
denegacion_servicio	LIMITAR_BANDA en la víctima	**Nunca**
acceso_consumado	MATAR_CONEXION (corta la sesión viva)	Según el perfil
exfiltracion	BLOQUEAR_DESTINO en el borde	**Nunca**
malware	AISLAR_NODO	**Nunca**

Lo que no encaja en ninguna familia se marca «no soportada» y no se actúa. Si es grave, pasa a un analista.

Anexo E. Por qué falló una contención

Cuando una contención no queda, el MDR dice por qué en la Consola, en Decisiones, en Trazas y en «Te toca».

Clase	Qué pasó	Qué hacer
F1	Orden rechazada antes de salir	Revisa la alerta: un parámetro no era válido
F2	Equipo sin aprovisionar	Dalo de alta o fija su clave del host en Conectividad
F3	**La clave del host cambió**	**Posible suplantación.** Compruébalo por otro canal antes de aceptar la clave
F4	El equipo no acepta la clave del conector	Ejecuta su paquete de alta
F5	Equipo inalcanzable	Comprueba que el equipo y sshd están en marcha y que la red llega
F6	sudo deniega la acción	Revisa el papel y el sudoers. Si falta la regla, es una «acción no ejecutable en este equipo»
F7	La acción falló dentro del equipo	Revisa la salida del comando
F8	**Se aplicó, pero ya no está**	**Posible contramedida:** alguien pudo deshacerla
F9	El conector no tiene clave	Genera la clave del conector en Conectividad

Clase	Qué pasó	Qué hacer
F10	Causa no identificada	Revisa la salida en bruto

Nota: si el equipo **estaba verificado** y ahora da F4, F5 o F6, es una **regresión** y se marca como posible ataque: alguien pudo cortar el acceso del SOC. Compruébalo antes de reaprovisionar.

Anexo F. Problemas frecuentes en la instalación

Síntoma	Causa probable y qué hacer
El servicio no arranca: «define TRIAJE_…»	Falta esa variable en `/etc/mdr/triaje.env`
El conector sigue «sin configurar»	`TRIAJE_SSH_MODO` no es exactamente `directo` (¿un comentario al final de la línea?) o aún no se generó la clave
No llegan alertas por fichero	`triaje` no puede leer el `alerts.json` ; dale lectura (por ejemplo, el grupo del SIEM)
No llegan alertas por red	La IP del SIEM no está en `TRIAJE_PERMITIR` , el cortafuegos corta el 6514, o falla el TLS. El registro del servicio dice por qué rechaza
Llegan alertas pero no se contiene nada	Sus reglas salen sin cubrir en `mdr validar-alertas` , o el nombre del equipo no coincide con el del perfil
Se abrió la automatización, pero todo sigue esperando a un analista	Falta la postura: ejecuta `mdr escanear` y reinicia (sección 7)
La consola se ve pero no deja aprobar	El túnel no usa el mismo puerto a los dos lados (sección 9)
«El daemon no reconoce ese token»	El token no está en `TRIAJE_CONSOLA_OPERADORES` , o no se reinició tras añadirlo
No se puede generar la clave del conector	`/var/lib/mdr` no es de `triaje` , o falta `ssh-keygen`
Un equipo queda «bloqueada»	Su clave del host cambió. Compruébalo con su administrador antes de aceptarla
Aviso «geolocalización: no se pudo cargar la base» (o «ASN: …»)	Falta el fichero de `TRIAJE_GEOIP` (o de `TRIAJE_ASN`) o no es válido. Instálalo con `mdr instalar-geoip` (o `mdr instalar-asn`), sección 6
«Sin datos del monitor de servicios»	Falta `TRIAJE_SALUD` , o `triaje` no puede leer ese fichero (sección 29)

Anexo G. Preguntas frecuentes

Operar

¿Por qué una contención no se ejecutó sola? Porque el perfil del cliente la retiene: toca un servicio, un equipo crítico, un equipo interno, o es de las acciones que nunca se automatizan. O porque la automatización está en pausa. La decisión espera en Aprobaciones y su detalle dice por qué necesita a un humano.

¿Por qué no se automatiza nada si el perfil lo permite? Lo más probable es que falte la postura: sin saber qué puertos tiene abiertos el equipo, el MDR no alcanza la confianza necesaria. Pide a la administración que ejecute `mdr escanear`.

¿Cómo deshago un bloqueo? En «Contenciones activas», «Revertir…» en su fila. El MDR quita la regla en el equipo y lo anota con tu nombre. Para un bloqueo en masa hay que escribir el número de contenciones.

¿Qué hago si sale «posible ataque»? No lo trates como un problema de configuración. Comprueba por otro canal qué pasa con ese equipo (la clave de su host, si alguien deshizo la regla, si alguien cortó el acceso del SOC) antes de reaprovisionarlo o aceptar una clave nueva.

¿Por qué no me llegan avisos? Activa la campana y acepta el permiso del navegador. Solo avisa de decisiones **nuevas**, no de las que ya estaban en la cola al abrir la consola.

Red y configuración

¿Por qué un equipo sale en el mapa si no lo di de alta? Porque el mapa sale del perfil del cliente, no de Conectividad. Conectividad solo gestiona cómo entra el MDR en cada equipo; las altas nuevas entran en el mapa cuando se completan.

¿Se pierde algo al reiniciar el MDR? La pausa, el estado operativo de Conectividad y la memoria de fallos. La traza, las políticas, el inventario y las contenciones activas se conservan.

El sistema

¿Quién decide la acción? Una política determinista, a partir de la familia del ataque, y la filtra el perfil del cliente. La justificación que acompaña a cada decisión se apoya en los mismos datos.

¿Qué significa «no soportada»? Que la alerta cae fuera de las diez familias que el MDR trata. El sistema prefiere decirlo a inventar una respuesta. Si es grave, pasa a un analista.

¿El MDR sustituye al SIEM o a un antivirus? No. Refina lo que el SIEM ya detecta; lo que el SIEM no ve, el MDR tampoco.

Anexo H. Glosario

Término	Significado
Alerta	Lo que envía el SIEM cuando detecta algo. Es la entrada del MDR
Aprobación	Decisión que el perfil retiene para que la resuelva un analista
Campaña	Los incidentes de un mismo bloque de IPs (/24). Se gestiona como un caso
Cascada	Equipos que caen si cae otro del que dependen
Causa del fallo	Por qué no quedó una contención: de F1 a F10
Clase	Lo que el motor concluye de un incidente: un tipo de amenaza, un falso positivo o «no soportada»
Conector	La parte del MDR que entra por SSH en los equipos para contener
Contención	La acción que corta el ataque: bloquear una IP, cortar una conexión, aislar un equipo…
Decisión	Lo que el MDR resolvió sobre un incidente, con su desenlace

Término	Significado
Deriva del sudoers	Diferencia entre lo que sudo permite en un equipo y lo que su papel necesita
Equipo MDR	El equipo de la red del cliente donde corre el MDR
Escalada	Contener en el cortafuegos cuando no se puede en el equipo atacado
Familia	El tipo de ataque: fuerza bruta, reconocimiento, malware… Hay diez
Huella	La identidad de la clave del host de un equipo, que se fija una vez
Incidente	Un ataque concreto, con sus alertas agrupadas
Pausa de la automatización	El interruptor que hace que todo pase a esperar a un analista
Papel	Servidor, cortafuegos o puesto: decide qué acciones se pueden ejecutar en un equipo
Perfil	Todo lo que el MDR sabe del cliente: equipos, red, dependencias y política
Posible ataque	Fallo que no puede tratarse como configuración: clave cambiada, contención deshecha o regresión
Regresión	Un equipo que estaba verificado y dejó de funcionar
Reversión	Quitar una contención y devolver el equipo a como estaba
SIEM	El sistema de detección del cliente (Wazuh)
SLA	Plazo para que un analista resuelva una aprobación: 15 minutos por defecto
Supresión	Repeticiones de algo ya decidido que no se vuelven a procesar
Traza	El registro de todo lo que decide el MDR, encadenado por hash
Watchlist	Lista de IPs o bloques que el analista marca como sospechosos. No cambia decisiones
Zona	Grupo de equipos de la red del cliente, colgado de un cortafuegos

Anexo I. Límites conocidos

Límite	Consecuencia
Solo entiende alertas de Wazuh, una por línea	Otro SIEM necesita un adaptador; syslog y CEF no se reciben todavía
Solo contiene por SSH en equipos Linux	Los equipos sin SSH quedan en manos humanas o se contienen en el equipo Linux de paso
La traza es un único fichero que crece	Hay que vigilar su tamaño; la retención no la recorta
La postura se lee al arrancar	Tras cada `mdr escanear` hay que reiniciar el servicio
La geolocalización es por país, no por ciudad	Las bases se actualizan cada mes; una IP reasignada puede salir con el país u organización anteriores hasta la siguiente
Sin inicio de sesión corporativo (SSO)	El acceso es por túnel SSH y token por analista

Límite	Consecuencia
Un perfil por instalación	Varios clientes, varias instalaciones
Cambiar el perfil exige reiniciar	Lo que vive en memoria (pausa, memoria de fallos) se pierde al reiniciar